Access Control Concepts and Principles

Introduction

Access control is a fundamental component of security that determines who can access resources within an organization. Understanding core concepts such as the roles of subjects and objects, system behaviors during failures, and key access control principles helps organizations protect sensitive information and resources. This document outlines these essential concepts and provides clear explanations for each.

1. Subjects and Objects

Subject: An entity that requests access to a resource. While typically a person (e.g., an employee), a subject can also be a device, a running program, or a computer.

- Example: An employee logging into a company database.

Object: The resource that the subject wants to access. Objects can include files, databases, applications, computers, or records.

- Example: The company database accessed by the employee.

Relationship: Access control mechanisms focus on ensuring only authorized subjects access specific objects, forming the foundation of organizational security.

2. System Failure Behaviors: Fail Open vs. Fail Closed

Fail Closed

Definition: If the access control system fails, all access requests are denied.

Security Implication: Preferred in most security-sensitive environments because it prevents unauthorized access during failures.

Example: In a keycard access system, a power outage keeps all doors locked.

CYVITRIX LEARNING

Fail Open

Definition: If the access control system fails, all access requests are granted.

Security Implication: Less secure, but may be necessary where safety is a priority over security.

Example: Emergency exits that unlock automatically during a fire alarm for safe evacuation.

Choosing an Approach: The decision between fail open and fail closed depends on balancing safety and security requirements for the specific environment.

3. Need to Know Principle

Definition: Users are granted access only to information required for their job duties.

Purpose: Minimizes the risk of unauthorized access to sensitive information.

Example: A marketing employee does not have access to financial records, since it is not essential for their work.

Benefit: Reduces the chance of both accidental and intentional misuse of information.

4. Least Privilege Principle

Definition: Users receive the minimum permissions necessary to perform their tasks.

Purpose: Limits potential damage from misuse of access rights, whether accidental or deliberate.

Example: An employee who only needs to view a report does not have permission to edit or delete it.

Implementation:

- Regular audits and reviews of user privileges.
- Adjusting access rights as roles or job duties change.

Benefit: Reduces the risk of privilege escalation, where a user gains more access than intended.

5. Segregation of Duties

Definition: Dividing tasks and privileges among multiple people to prevent excessive control by any one individual.

CYVITRIX LEARNING

Purpose: Reduces the risk of fraud, errors, and malicious activities.

Example: In accounting, creating a payee, approving payment, and issuing payment are handled by different individuals.

IT Example: Requesting and provisioning user accounts are performed by separate staff members.

Benefit: Establishes checks and balances, decreasing the risk of insider threats.

6. Split Custody (Dual Control)

Definition: Access to sensitive resources or critical knowledge is divided among two or more individuals.

Purpose: Ensures that no single person has full control, enhancing security for critical operations.

Example:

- An encryption key password is split between two people, each knowing only part of it.
- A vault combination is divided so multiple people must cooperate to gain access.

Use Cases: Particularly important where integrity and confidentiality of highly sensitive resources are vital.

Summary

Effective access control relies on understanding the roles of subjects and objects, planning for system failure scenarios, and applying key principles such as need to know, least privilege, segregation of duties, and split custody. These concepts help organizations protect sensitive resources, prevent unauthorized access, and mitigate the risks associated with errors or malicious activities. Regularly reviewing and updating access control measures ensures that security remains robust as organizational needs evolve.

CYVITRIX LEARNING

Access Control Concepts Quiz

Questions

1. In the context of access control, what is a "subject"?

A) The resource being accessed

B) The entity requesting access to a resource

C) The process of restricting access

D) The policy governing access rights

B _____

2. Which of the following best describes an "object" in access control?

A) The entity making a request

B) The device enforcing security policies

C) The resource that is being accessed

D) The set of user credentials

C _____

3. What does a "fail closed" access control system do during a failure?

A) Grants all access requests

B) Denies all access requests

C) Logs all access attempts but allows access

D) Asks for additional authentication

B _____

4. Why do security professionals generally prefer "fail closed" over "fail open"?

A) It improves system performance

B) It prevents unauthorized access during failures

C) It is easier to manage

CYVITRIX LEARNING

D) It reduces administrative overhead

B

5. Which scenario illustrates a "fail open" system?

A) All doors remain locked during a power outage

B) A firewall blocks all network traffic if it crashes

C) Emergency exits unlock during a fire alarm

D) User accounts are disabled after a failed login attempt

C

6. The "need to know" principle requires that:

A) Users have access to all company data

B) Access is based solely on seniority

C) Users are given access only to the information necessary for their job

D) All employees are given the same access rights

C

7. Which of the following is an example of the "need to know" principle?

A) Marketing staff accessing financial records

B) IT staff having administrative access to all servers

C) HR employees accessing only personnel files relevant to their work

D) All employees accessing the company's source code

C

8. The "least privilege" principle ensures that:

A) All users have maximum access rights

B) Users have the minimum access necessary to perform their tasks

C) Only managers have access to sensitive data

D) Privileges are never audited

B

CYVITRIX LEARNING

9. What is a potential risk if the least privilege principle is not enforced?

A) Increased productivity

B) Privilege escalation attacks

C) Lower risk of insider threats

D) More efficient system performance

B

10. Which practice helps maintain the principle of least privilege over time?

A) Ignoring user privilege changes

B) Regular audits and reviews of user privileges

C) Providing blanket access to all resources

D) Allowing self-service privilege escalation

B

11. What is the main goal of segregation of duties?

A) To simplify administrative tasks

B) To ensure one individual controls all critical processes

C) To divide tasks among multiple people to reduce fraud and errors

D) To eliminate the need for access controls

C

12. Which example demonstrates segregation of duties in an accounting department?

A) One person creates payees, approves, and issues payments

B) The IT manager is also the financial auditor

C) Different individuals handle payee creation, payment approval, and payment issuance

D) All staff have access to payroll records

C

13. In IT, how can segregation of duties be implemented?

A) Having one person request and provision user accounts

CYVITRIX LEARNING

B) Splitting the roles of requesting and provisioning user accounts between two people

C) Allowing all users to create and delete accounts

D) Assigning all IT responsibilities to one administrator

B

14. What is "split custody" (dual control) in access control?

A) Giving a single person all necessary credentials

B) Splitting access or knowledge of a critical resource among multiple people

C) Allowing only one person to access sensitive data

D) Providing everyone with partial credentials

B

15. A secure vault requires two people, each with part of the combination, to access it. This is an example of:

A) Segregation of duties

B) Least privilege

C) Split custody

D) Need to know

C

16. Why is split custody important for highly sensitive resources?

A) It speeds up access to resources

B) It ensures no single person has full control, enhancing security

C) It reduces the need for audits

D) It simplifies resource management

B

17. Which principle is most effective in limiting the potential damage from accidental or intentional misuse of access rights?

A) Fail open

B) Segregation of duties

CYVITRIX LEARNING

C) Least privilege

D) Need to know

C

18. Which of the following best describes the relationship between subjects and objects in access control?

A) Objects request access to subjects

B) Subjects are always people, objects are always files

C) Subjects request access to objects

D) Subjects and objects are interchangeable terms

C

19. What is a key benefit of implementing the need to know principle?

A) Increases the risk of information leaks

B) Minimizes unauthorized access to sensitive information

C) Makes privilege escalation easier

D) Allows unrestricted access to all resources

B

20. What is a classic risk reduced by segregation of duties?

A) Hardware failure

B) Insider fraud

C) Power outages

D) Data redundancy

CYVITRIX LEARNING

Answers and Explanations

1. **Answer: B** - Explanation: In access control, a subject is the entity (person, device, program, etc.) requesting access to a resource.

---

2. **Answer: C** - Explanation: An object is the resource (file, database, etc.) that the subject wants to access.

---

3. **Answer: B** - Explanation: Fail closed systems deny all access requests during a failure, enhancing security.

---

4. **Answer: B** - Explanation: Denying access during failures prevents unauthorized access.

---

5. **Answer: C** - Explanation: Emergency exits unlocking during a fire alarm is a fail open scenario prioritizing safety.

---

6. **Answer: C** - Explanation: Need to know limits access to only what is necessary for a user's job.

---

7. **Answer: C** - Explanation: HR employees accessing only necessary personnel files exemplifies need to know.

---

8. **Answer: B** - Explanation: Least privilege means users only get the minimal access needed to do their job.

---

9. **Answer: B** - Explanation: Without least privilege, users may gain more access than needed and escalate privileges.

---

10. **Answer: B** - Explanation: Regular audits ensure access remains appropriate and least privilege is maintained.

CYVITRIX LEARNING

---

11. **Answer: C** - Explanation: Segregation of duties divides tasks to prevent too much power being concentrated with one person.

---

12. **Answer: C** - Explanation: Separating payee creation, approval, and issuance reduces fraud and errors.

---

13. **Answer: B** - Explanation: Splitting requesting and provisioning user accounts helps implement segregation of duties in IT.

---

14. **Answer: B** - Explanation: Split custody means access or knowledge is divided among multiple people for security.

---

15. **Answer: C** - Explanation: Requiring two people to access a vault is a classic example of split custody.

---

16. **Answer: B** - Explanation: Split custody prevents one person from having full control, enhancing security for sensitive resources.

---

17. **Answer: C** - Explanation: Least privilege most directly limits the impact of accidental or intentional misuse of access rights.

---

18. **Answer: C** - Explanation: Subjects request access to objects in access control terminology.

---

19. **Answer: B** - Explanation: Need to know minimizes the risk of unauthorized access to sensitive data.

---

20. **Answer: B** - Explanation: Segregation of duties reduces the risk of insider fraud by distributing responsibilities.

CYVITRIX LEARNING